

Smart Teams

Complete Functionality Guide — every capability of the platform, A to Z

This document explains what the platform actually does, feature by feature, in plain language — not endpoint-by-endpoint (see the companion API Reference for that). Each entry covers what the feature is, how it behaves, and any real design decisions or trade-offs worth knowing about. Entries are ordered A–Z by feature name; several letters map to a cross-cutting design principle rather than a single screen, called out explicitly where that's the case.

Contents

- A. Attendance & Check-In
- B. Breaks & Break Budgets
- C. Compensation & Compensation History
- D. Device Pinning & Device-Change Requests
- E. Earnings (Self-Service Pay Breakdown)
- F. Face Verification & Liveness
- G. Geofencing
- H. Holidays
- I. Integrations: API Keys & Webhooks
- J. JWT Sessions & Single-Session Enforcement
- K. KYC (Biometric Enrollment)
- L. Leave Management
- M. Multi-Tenancy
- N. Notifications
- O. Overtime
- P. Payroll & Payslips
- Q. QR Attendance
- R. Roles & Privileges (RBAC)
- S. Super Admin & Platform Oversight
- T. Teams
- U. Uptime, Health Checks & Monitoring
- V. Versioning & Rate Limiting
- W. Work From Home (WFH)
- X. Cross-Tenant Isolation ("X" for cross-cutting)
- Y. "Your Own Data" Self-Service Pattern ("Y" for the shared design principle)
- Z. Zero-Trust Verification at Submit Time



Attendance & Check-In

The core loop the whole platform is built around

What it is

The authoritative record of who was working, when, and where. A check-in is never just "a button press" — every submission is independently re-verified server-side against identity, location, and (optionally) network, regardless of what any earlier preview step said.

How it works

An employee opens the check-in flow, a camera burst is captured and run through face verification (see "Face Verification & Liveness" below), GPS is checked against the tenant's configured office geofence (or a WFH home location, see "Work From Home"), and if the tenant requires it, the device's network is checked against a configured office Wi-Fi/IP. Only after all of that passes does POST /api/attendance actually write the record.

Late arrivals

A check-in after the shift's grace period is written as pending, not automatically approved — it goes to a manager's approval queue, with the employee's typed explanation attached.

Continuous presence

While checked in, the client periodically sends a heartbeat (location ping) so drift outside the geofence or off the approved network mid-shift can be flagged, without blocking the employee's ongoing work.



Breaks & Break Budgets

Time-boxed breaks with a daily budget that now has real financial teeth

What it is

Employees start/end break sessions (lunch, tea, personal, etc.) against a tenant-configured daily time budget.

Enforcement

A background scanner runs every minute checking every active break against the budget; one that overstays is auto-ended and logged as a violation, visible to whoever reviews alerts.

Pay impact

Minutes over the daily budget are now charged against pay on the Earnings page (see "Earnings" below) — previously this was only ever an alert, never tied to money.



Compensation & Compensation History

What each employee is paid, and a full paper trail of every time it changed

What it is

Each employee has an individual compensation profile (annual CTC, overtime rate, and a breakdown of salary components — Basic, HRA, PF, allowances, deductions) that everything else (payroll, earnings, payslips) is computed from.

Role defaults

Rather than configuring every employee from scratch, an admin can set one default compensation template per role; any employee without their own individual override automatically inherits their role's default, live — edit the default and everyone in that role sees the change immediately.

Change history

Every save of an employee's compensation is diffed against what it was before and permanently logged — CTC changes, and every component added, removed, or adjusted in value, with who made the change and when. Previously, saving simply overwrote the old numbers and deleted the old component rows outright; nothing survived. Both admins (looking up any employee) and employees themselves (their own record only) can view this history, reached via a dedicated History page.



Device Pinning & Device-Change Requests

One account, one trusted device

What it is

On first login, an account is pinned to a specific device ID. Every subsequent check-in is checked against that pinned ID — a mismatch is treated as a fraud signal (FRAUD_DEVICE_MISMATCH) and logged to the audit ledger, with the tenant admin escalated by email.

Changing devices legitimately

An employee who gets a new phone submits a device-change request; an admin reviews and approves it before the new device is trusted, rather than the pin silently updating itself.



Earnings (Self-Service Pay Breakdown)

Day-by-day and monthly, exactly what you were paid and why

What it is

A dedicated page every non-admin employee has, showing real computed pay detail: hours worked each day, overtime beyond the shift length and what it paid, minutes over the break budget and what that cost, and leave taken with whether it was paid or unpaid — toggled between a Daily view (one row/card per day) and a Monthly rollup that reconciles exactly with the numbers tenant admins see in Payroll.

Why it's new

Before this existed, overtime was hardcoded to zero everywhere in the system, and break overages were never priced into pay at all — this is the first real implementation of either.

Mobile

The dense day-by-day table is desktop/tablet-only; on a phone it becomes a stacked card per day instead of an unreadable horizontal scroll.

Own compensation history

A third toggle ("History") on the same page lets an employee see every past change to their own pay, not just the current month.



Face Verification & Liveness

Server-side biometric identity, never trusted client-side

What it is

A camera burst is sent to a separate Python microservice (InsightFace, running entirely server-side) which returns a face embedding, a liveness score, and which specific challenge actions (blink, turn head, smile, etc.) it actually detected in the burst — the browser never runs any ML itself.

Identity match

The returned embedding is compared (cosine similarity) against every embedding captured during that employee's own KYC enrollment; the best match must clear a threshold, currently 0.5, tuned from real match/mismatch data collected from this deployment after a false-accept was reported and confirmed.

Liveness

Landmark micro-movement across the burst distinguishes a live person from a printed photo or a frozen video replay — a static image scores near zero movement.

Challenge-response

A server-issued random subset of the employee's own previously-verified poses must be confirmed in the live burst, so a pre-recorded video of the right person performing the wrong action still fails.

A known limit, documented honestly

Threshold tuning alone cannot separate every possible false match — a genuinely different person who closely resembles the enrolled user can, in rare cases, still score inside the legitimate same-person range. The real remedy in that case is re-enrolling KYC with a better, more varied capture burst, not further threshold tuning; device pinning and geofencing remain independent backstops regardless.



Geofencing

Location as one independent layer of proof, not the whole picture

What it is

Every office check-in is checked against a configured latitude/longitude/radius for the tenant (or branch); a WFH check-in is checked against the employee's own registered home location instead.

Independence

Geofencing, face match, and device pinning are all checked independently — passing one does not substitute for another, and the authoritative submit endpoint re-checks all of them itself regardless of what any earlier preview step reported.



Holidays

Company-wide calendar plus employee-chosen optional days

What it is

A tenant-managed holiday calendar (so a holiday shows as "Holiday" in reports, not a false "Absent"), plus optional/floating holidays an employee can choose for themselves within a tenant-configured yearly limit.

Bulk import

A whole country/region's standard public holidays can be imported in one action rather than entered one at a time.



Integrations: API Keys & Webhooks

Letting another application talk to this one, safely

Service accounts (API keys)

A tenant admin can mint a long-lived API key scoped to an explicit, self-chosen privilege list — for a partner app that needs to call this API without holding a real employee's login. The raw key is shown exactly once at creation and can only ever be revoked and reissued afterward, never retrieved again.

Webhooks

A tenant admin can subscribe a URL to specific events (a check-in, a leave request being approved, etc.); each delivery is a signed HTTP POST the receiving app can verify genuinely came from this server, so partners can react to real events instead of polling for changes.

Scoped, not blanket

A service account can only ever be granted privileges its creator already holds themselves — the same "can't delegate more than you have" rule applied to every other privilege grant in the system.



JWT Sessions & Single-Session Enforcement

Stateless tokens, but a stateful revocation switch

What it is

Login issues a signed JSON Web Token, valid 24 hours, carrying the user's ID, role, and tenant. Every authenticated request is checked against it.

Single active session

A second login to the same account invalidates the first session's token immediately, even though it has not technically expired — logging in on a new device signs you out everywhere else. This is enforced by comparing the token's embedded session ID against the one currently stored on the user's own row, not by tracking every issued token.



KYC (Biometric Enrollment)

The one-time setup everything else depends on

What it is

A guided, 8-pose enrollment flow (look center, turn left/right, look up/down, smile, open mouth, blink) captured once per employee, server-verified pose by pose, that produces the set of face embeddings every future

attendance check is compared against.

Partial retry

If some poses could not be confirmed (bad lighting, camera angle), only those specific poses need to be redone — not the entire enrollment burst.

Tenant-wide off switch

A tenant can disable KYC entirely, company-wide, letting employees check in via GPS-within-radius alone with no biometric step — a deliberate policy choice some tenants may want, not an oversight.



Leave Management

Requests, policies, balances, and the approval queue

What it is

Employees request leave against tenant-configured leave types (each with its own rules — advance-notice requirements, half-day support, whether it needs approval at all); admins configure the policies and approve or reject requests.

Balance tracking

Remaining balance per leave type is computed live from approved requests, with support for manual adjustments (carry-forwards, corrections) that are themselves logged with who made them and why.

Overlap protection

A new request cannot be submitted if it overlaps a date range the employee already has a pending or approved request for.



Multi-Tenancy

Every tenant is an isolated company, sharing one deployment

What it is

The entire platform is multi-tenant — every table that matters is scoped by tenantId, so Company A's employees, attendance, payroll, and settings are never visible to Company B, even though they run on the same database and application instance.

Onboarding

A prospective company submits a public sign-up request; a platform super admin reviews and approves it, which is the single action that actually provisions the new tenant and its first admin account.



Notifications

In-app alerts for the events that need a human's attention

What it is

A read/unread notification feed per user — salary changes, leave decisions, new tenancy requests (for super admins), and more, each with mark-as-read (individually or all at once).



Overtime

Real computed overtime pay, not a hardcoded zero

What it is

Hours worked beyond the tenant's configured shift length on a day the employee actually checked in, paid at a configurable overtime rate.

Weekend/holiday work

If someone genuinely works a scheduled-off day (a weekend or a holiday), every hour of that counts as overtime rather than being silently discarded — a real bug found and fixed during development, where the system used to resolve to "weekend"/"holiday" status before ever checking whether a real check-in existed that day.



Payroll & Payslips

Monthly numbers, computed live and permanently snapshotted

Live view

An employee's current-month payroll (gross, deductions, net) is computed live from their compensation profile and this month's approved leave — not a stale stored number.

Permanent snapshots

The first time a given month's payroll is looked up, it is permanently snapshotted as a payslip; later compensation changes never retroactively rewrite a past payslip, even though the live view for future months reflects the new numbers immediately.

PDF payslips

Any past payslip snapshot can be downloaded as a formatted PDF.

Tenant-wide settings

Working days per month, overtime rate, and leave-penalty rules are configured once per tenant and feed every employee's payroll calculation.



QR Attendance

A faster check-in path for a shared entry point

What it is

A manager runs a QR display session (e.g. on a lobby tablet); the code rotates on a timer so a photographed/reused code quickly stops working. Employees scan it to check in, still subject to whatever additional checks the tenant's QR policy requires — geofence, face, Wi-Fi, or device trust, independently configurable.

Manual override

A scan that fails automated verification can be manually approved by an admin, with a required, audit-logged reason — never a silent bypass.



Roles & Privileges (RBAC)

Fine-grained permissions, not a fixed role list

What it is

Every capability in the system is gated behind a specific privilege string (e.g. payroll.manage, attendance.approve), not a hardcoded role check. Two tiers (super_admin, tenant_admin) are always unrestricted; every other role — including entirely custom role names a tenant admin invents — gets an explicitly configured default privilege set, editable at any time.

Individual overrides

A specific employee can be granted (or have revoked) an individual privilege beyond their role's default, for narrow cases like QR display access or WFH access, without changing the whole role.

Delegation ceiling

Nobody can grant a privilege they do not themselves hold — enforced the same way whether it is a role's default privileges or a service account's scoped API key.



Super Admin & Platform Oversight

One tier above every tenant

What it is

The role: super_admin (a platform operator, not a member of any one company) reviews and approves new tenancy sign-ups, can suspend or reinstate any tenant, and sees cross-tenant analytics — but never sees inside any one tenant's own employee/attendance/payroll data beyond aggregate counts.



Teams

A manager's own "my team" workspace

What it is

Separate from tenant-wide administration, a manager (anyone holding team.manage) gets a personal workspace scoped to their own team's members, drawn from their department.



Uptime, Health Checks & Monitoring

How the platform watches itself

Health endpoints

Separate liveness (/api/health), database-readiness (/api/health/db), and face-service-readiness (/api/health/face) checks, used by the hosting platform's own uptime monitoring and by the frontend to decide whether biometric flows are even safe to attempt right now.

Crash resilience

An error thrown outside any individual request handler's own error handling no longer crashes the entire process and drops every connected user — it is caught, logged, and the process stays alive.

Optional error monitoring

Sentry integration is available (env-var gated, a genuine no-op if unconfigured) to forward exceptions for alerting/aggregation once running as more than one instance.



Versioning & Rate Limiting

How the API stays stable for integrators

API versioning

External integrations call the /api/v1 prefix, a transparent rewrite to the same handlers — guaranteed stable; a breaking change ships as /v2 first rather than changing /v1 in place.

Rate limits

A generous general limit (300 requests/minute, keyed by authenticated user where possible so one busy office network is not throttled as a single client) plus a much tighter limit specifically on login attempts, to slow brute-force guessing.



Work From Home (WFH)

A second attendance mode with its own eligibility policy

What it is

Instead of the office geofence, a WFH check-in is checked against the employee's own registered home location. Whether WFH is available at all is a tenant-wide policy (which roles are allowed, which weekdays, a monthly quota, whether approval is required).

Home location changes

The first registration is self-service; any change after that goes through a manager approval flow, specifically so an employee cannot silently redefine "home" without anyone noticing.



Cross-Tenant Isolation ("X" for cross-cutting)

The guarantee that makes multi-tenancy safe

What it is

Every privileged query is scoped by the caller's own tenantId, checked server-side on every request — not something the frontend enforces or could bypass by tampering with a request. A user from one tenant cannot see, modify, or even discover the existence of another tenant's data by any documented API call.



"Your Own Data" Self-Service Pattern ("Y" for the shared design principle)

The consistent "mine" convention across the API

What it is

Several endpoints (`/api/attendance/mine`, `/api/leave/mine`, `/api/payroll/mine`, `/api/earnings/mine`, `/api/payroll/compensation-history/mine`) follow the same deliberate pattern: any authenticated user, regardless of role, can call them with no special privilege check beyond being logged in, because the target is always implicitly "me" — there is nothing to authorize beyond identity itself.



Zero-Trust Verification at Submit Time

Nothing is ever taken on the client's word

What it is

Every multi-step flow in the system (attendance's face/location/network preview steps, QR's validation-then-verification steps) is explicitly designed so the FINAL, authoritative endpoint re-checks everything itself from scratch — identity, liveness, location, device, network — rather than trusting that an earlier "preview passed" response was genuine. A client could skip or fake any preview call and it would make no difference to what actually gets recorded.